Sécurité : Analyse de risques

14 mars 2024

Identifier les risques et évaluer leur vraisemblance et leur gravité pour mettre en place les mesures de sécurité appropriées.

En parallèle de la mise en conformité aux précautions élémentaires présentées dans ce guide, il est pertinent, voire obligatoire selon la criticité des traitements, de réaliser des analyses de risques relative à la protection des données. Ces analyses permettent de décider des mesures de sécurité complémentaires, adaptées au contexte, permettant de limiter l'impact sur les personnes concernées par le traitement.

Les précautions élémentaires

Identifier les traitements de données personnelles pour lesquels une **analyse d'impact relative à la protection des données (AIPD) doit obligatoirement être menée selon le RGPD**. Une AIPD comporte non seulement une partie dédiée à la réflexion sur les risques, objet de la présente fiche, mais également une partie dédiée au volet juridique des traitements de données personnelles.

Mener une analyse de risques, même minimale, selon les trois étapes suivantes :

Recenser les traitements de données personnelles, automatisés ou non, les données traitées (ex. : fichiers clients, contrats) et les supports sur lesquels ces traitements reposent :

- les matériels (ex. : serveurs, ordinateurs portables, disques durs) ;
- les logiciels (ex. : systèmes d'exploitation, logiciels métier) ;
- les ressources d'informatique en nuage (cloud) utilisés (ex. : **SaaS**, **PaaS**, IaaS) ;
- les canaux de communication logiques ou physiques (ex. : fibre optique, Wi-Fi, Internet, échanges verbaux, coursiers) ;
- les supports papier (ex. : documents imprimés, photocopies) ;
- les locaux et installations physiques où se situent les éléments précédemment cités (ex. : locaux informatiques, bureaux). Cette étape mérite d'être menée indépendamment de toute analyse de risques (voir la fiche n°1 - Piloter la sécurité des données)

Apprécier les risques engendrés par chaque traitement :

1 Identifier les impacts potentiels sur les droits et libertés des personnes concernées, pour les trois évènements redoutés suivants :

- **accès illégitime à des données** (ex. : usurpation d'identité consécutive à la divulgation des fiches de paie de l'ensemble des salariés d'une entreprise) ;
- **modification non désirée de données** (ex. : accusation à tort d'une personne d'une faute ou d'un délit suite à la modification de journaux d'accès) ;
- **disparition temporaire ou définitive de données** (ex. : non-détection d'une interaction médicamenteuse du fait de l'impossibilité d'accéder au dossier électronique du patient).

2 Identifier les sources de risques

Qui ou qu'est-ce qui pourrait être à l'origine de chaque évènement redouté ?, en prenant en compte des sources humaines internes et externes (ex. : administrateur informatique, utilisateur, attaquant externe, concurrent) ainsi que des sources non humaines internes et externes (ex. : eau, épidémie, matériaux dangereux, virus informatique non ciblé).

3 Identifier les menaces

Qu'est-ce qui pourrait permettre que chaque évènement redouté survienne ? Ces menaces surviennent sur les supports identifiés précédemment (matériels, logiciels, canaux de communication, supports papier, etc.), qui peuvent être :

- utilisés de manière inadaptée (ex. : abus de droits, erreur de manipulation) ;
- modifiés (ex. : piégeage logiciel ou matériel ou « *keylogger* », installation d'un logiciel malveillant) ;
- perdus (ex. : vol d'un ordinateur portable, perte d'une clé USB) ;
- observés (ex. : observation d'un écran dans un train, **géolocalisation** d'un matériel) ;
- détériorés (ex. : vandalisme, dégradation du fait de l'usure naturelle) ;
- surchargés (ex. : unité de stockage pleine, attaque par déni de service).

4 Déterminer les mesures existantes ou prévues

Qui permettent de réduire chaque risque (ex. : contrôle d'accès, sauvegardes, traçabilité, sécurité des locaux, chiffrement, anonymisation).

5 Estimer la gravité

Impact ou préjudice potentiel pour les personnes concernées, **et la vraisemblance** (probabilité qu'ils se réalisent) des risques, au regard des éléments précédents (exemple d'échelle utilisable pour l'estimation : négligeable, modérée, importante, maximale).

Le tableau suivant peut être utilisé pour formaliser cette réflexion :

ÉVÈNEMENT REDOUTÉ	IMPACTS SUR LES PERSONNES	PRINCIPALES SOURCES DE RISQUES	PRINCIPALES MENACES	MESURES EXISTANTES OU PRÉVUES	GRAVITÉ POUR LES PERSONNE
Accès illégitime à des données					
Modification non désirée de données					
Disparition de données					

Mettre en œuvre et vérifier les mesures prévues.

Si les mesures existantes et prévues sont jugées appropriées, il convient de s'assurer qu'elles soient appliquées et contrôlées (voir la fiche n°1 - Piloter la sécurité des données). Sinon, des mesures supplémentaires doivent être identifiées et mises en œuvre pour réduire la gravité et/ou la vraisemblance des risques associés.

Revoir régulièrement l'analyse de risques et, en particulier, en cas de modification du système ou du contexte du traitement.

Ce qu'il ne faut pas faire

- Oublier l'impact pour les personnes et seulement considérer l'impact pour l'organisme.
- Omettre une partie du traitement (ex. : collecte, partenaires, fin de vie des données) pour mener l'analyse.
- Ajuster les échelles de vraisemblance et de gravité pendant l'analyse au lieu de les définir en amont, en prenant en compte le contexte de l'organisme.

Pour aller plus loin

- Le RGPD introduit les **analyses d'impact relatives à la protection des données** (AIPD) et précise que celles-ci doivent au moins contenir « *une description [...] des opérations [...] et des finalités du traitement [...], une évaluation de la nécessité et de la proportionnalité [...], une évaluation des risques [...] et les mesures envisagées pour faire face aux risques [...] et visant à apporter la preuve du respect du règlement* » (article 35.7).

- La CNIL a publié des guides permettant de mener une AIPD. La CNIL a également publié un logiciel pour faciliter la conduite et la formalisation d'AIPD.

- La CNIL a également publié des listes de traitements pour lesquels une AIPD est requise ou non.

- **Les audits de sécurité sont un moyen essentiel pour évaluer le niveau de sécurité des systèmes sur lesquels reposent les(s) traitement(s) de données personnelles**. Réalisés de façon périodique, ils permettent de prendre en compte les évolutions du traitement et des menaces. Chaque audit doit donner lieu à un plan d'action dont la mise en œuvre devrait être suivie au plus haut niveau de l'organisme.

- **L'étude des risques sur la sécurité de l'information peut être menée en même temps que l'étude des risques sur la vie privée**. Ces approches sont compatibles.

- L'étude des risques permet de déterminer des mesures de sécurité à mettre en place. Il est nécessaire de **prévoir un budget** pour leur mise en œuvre.

< Fiche précédente : Gérer les incidents et les violations

Sommaire

Fiche suivante : Chiffrement, hachage, signature >